Dokumentacja API

# ServiceDesk — endpointy

Wszystkie trasy backendu: co robią i kto ma do nich dostęp

| Pozycja | Wartość |
|---|---|
| Wersja API | v1 |
| Bazowy adres | `http://localhost:8080/api/v1` |
| Podgląd i testy | `http://localhost:8080/swagger` (tylko Development) |
| Uwierzytelnianie | JWT w nagłówku `Authorization: Bearer <accessToken>` |
| Data | 10.11.2026 |

## Role

| Rola w systemie | Odpowiednik w specyfikacji | Zakres |
|---|---|---|
| Administrator | Administrator | Pełny dostęp: wszystkie zgłoszenia, sprzęt, użytkownicy, statystyki |
| Moderator | Technik | Własne zgłoszenia i przypisane do niego, podgląd sprzętu |
| User | Pracownik | Tylko własne zgłoszenia i własny sprzęt. Rola nadawana przy rejestracji |

Każdy endpoint wymaga zalogowania, chyba że w kolumnie „Kto" jest napisane „Każdy". Uprawnienia sprawdza API, ukrywanie przycisków we frontendzie nie jest zabezpieczeniem.

## Auth — /api/v1/auth

| Metoda | Route | Co robi | Kto |
|---|---|---|---|
| POST | `/api/v1/auth/register` | Zakłada konto z rolą User. Body: `email, password, firstName, lastName` | Każdy |
| POST | `/api/v1/auth/login` | Loguje i zwraca `accessToken` (15 min) i `refreshToken` (7 dni). 5 złych haseł blokuje konto na 15 min | Każdy |
| POST | `/api/v1/auth/refresh` | Wymienia `refreshToken` na nową parę tokenów. Stary przestaje działać | Każdy (z ważnym refresh tokenem) |
| POST | `/api/v1/auth/logout` | Unieważnia podany `refreshToken` | Każdy |
| GET | `/api/v1/auth/me` | Dane zalogowanego użytkownika i jego role | Zalogowany |

Na register, login i refresh obowiązuje limit 20 żądań na minutę z jednego IP (potem 429).

# Zgłoszenia — /api/v1/tickets

| Metoda | Route | Co robi | Kto |
|---|---|---|---|
| GET | /api/v1/tickets | Lista ze stronicowaniem. Filtry: status, priority, category, search, assigneeId, page, pageSize | User: swoje<br>Technik: swoje + przypisane<br>Admin: wszystkie |
| GET | /api/v1/tickets/{id} | Szczegóły zgłoszenia | Jak wyżej (cudze → 404) |
| POST | /api/v1/tickets | Tworzy zgłoszenie ze statusem New i numerem INC-000123 | Każdy zalogowany |
| PUT | /api/v1/tickets/{id} | Edycja tytułu, opisu, kategorii, priorytetu i urządzenia. Zamkniętego nie można edytować | Autor, Admin |
| PATCH | /api/v1/tickets/{id}/status | Zmiana statusu według reguł poniżej | Zależy od przejścia |
| PATCH | /api/v1/tickets/{id}/assignee | Przypisuje technika (assigneeId) albo zdejmuje przypisanie (null) | Admin |
| GET | /api/v1/tickets/{id}/comments | Lista komentarzy | Kto widzi zgłoszenie |
| POST | /api/v1/tickets/{id}/comments | Dodaje komentarz | Kto widzi zgłoszenie |
| GET | /api/v1/tickets/{id}/history | Historia zmian: status, przypisanie, tytuł, kategoria, priorytet, urządzenie | Kto widzi zgłoszenie |

## Reguły zmiany statusu (PATCH /status)

| Przejście | Kto | Warunek |
|---|---|---|
| New → InProgress | Przypisany technik, Admin | Zgłoszenie musi mieć przypisanego technika |
| InProgress → Resolved | Przypisany technik, Admin | Wymagane pole resolution |
| Resolved → Closed | Autor, Admin | — |
| Resolved → InProgress | Autor, Admin | Wymagane pole comment (powód ponownego otwarcia) |

Każde inne przejście (np. New → Closed) zwraca 409.

# Sprzęt — /api/v1/assets

| Metoda | Route | Co robi | Kto |
|---|---|---|---|
| GET | /api/v1/assets | Lista urządzeń. Filtry: type, search, ownerId | User: tylko swoje<br>Technik, Admin: wszystkie |
| GET | /api/v1/assets/{id} | Szczegóły urządzenia | User: swoje<br>Technik, Admin: wszystkie |
| GET | /api/v1/assets/{id}/tickets | Zgłoszenia powiązane z urządzeniem | Technik, Admin |
| POST | /api/v1/assets | Dodaje urządzenie. Numer seryjny i inwentarzowy muszą być unikalne (inaczej 409) | Admin |
| PUT | /api/v1/assets/{id} | Edycja urządzenia | Admin |
| DELETE | /api/v1/assets/{id} | Usuwa urządzenie. Zgłoszenia zostają, tylko bez powiązania z urządzeniem | Admin |

## Panel — /api/v1/dashboard

| Metoda | Route | Co robi | Kto |
|---|---|---|---|
| GET | `/api/v1/dashboard/stats` | Liczba zgłoszeń wg statusu i priorytetu, obciążenie techników, otwarte bez przypisania | Admin |

## Użytkownicy — /api/v1/users

| Metoda | Route | Co robi | Kto |
|---|---|---|---|
| GET | `/api/v1/users` | Lista użytkowników z rolami i informacją o blokadzie. Opcjonalnie `?role=Moderator` | Admin |
| GET | `/api/v1/users/technicians` | Osoby, którym można przypisać zgłoszenie (technicy i admini) | Admin |
| PATCH | `/api/v1/users/{id}/role` | Ustawia rolę: `Administrator`, `Moderator` lub `User`. Nie można odebrać sobie roli admina | Admin |
| PATCH | `/api/v1/users/{id}/lock` | Blokuje (`locked: true`) lub odblokowuje konto. Blokada wylogowuje użytkownika wszędzie. Nie można zablokować siebie | Admin |

Zmiana roli unieważnia stare tokeny użytkownika. Frontend odświeża token i dostaje nowe role.

## Pozostałe

| Metoda | Route | Co robi | Kto |
|---|---|---|---|
| GET | `/api/health` | Sprawdza, czy API działa | Każdy |
| GET | `/swagger` | Strona do testowania endpointów (tylko Development) | Każdy |
| GET | `/openapi/v1.json` | Opis API w formacie OpenAPI (tylko Development) | Każdy |
| GET | `/` | Przekierowuje na /swagger (tylko Development) | Każdy |

## Kody odpowiedzi

| Kod | Znaczenie | Kiedy |
|---|---|---|
| 200 / 201 | OK / Utworzono | Poprawne żądanie |
| 204 | Brak treści | Udana zmiana bez zwracanych danych |
| 400 | Błąd walidacji | Niepoprawne dane. Odpowiedź zawiera `errors` |
| 401 | Brak uwierzytelnienia | Brak tokenu albo token nieważny (np. po zmianie roli lub blokadzie) |
| 403 | Brak uprawnień | Rola nie pozwala na operację |
| 404 | Nie znaleziono | Zasób nie istnieje albo nie masz do niego dostępu |
| 409 | Konflikt | Niedozwolone przejście statusu, zduplikowany numer urządzenia |
| 429 | Za dużo żądań | Przekroczony limit prób logowania |

## Konta demonstracyjne

| Rola | Login | Hasło |
|---|---|---|
| Administrator | `admin@demo.local` | `Demo123!` |
| Moderator (technik) | `tech@demo.local` | `Demo123!` |
| User (pracownik) | `user@demo.local` | `Demo123!` |

Tworzone automatycznie w trybie Development (SeedDemoData).